

Agent Passport: a standard for agent-initiated payments

Abstract for the judges · Legis Labs · C:>DIR Global ‘Agentic Regulator’ Hackathon · Know Your Agent

The problem

Firms are letting AI agents read invoices and send payments. When an instruction arrives at a bank, the bank cannot tell which agent sent it, whether the agent was allowed to send it, or who answers if it was wrong. Since October 2024, UK banks reimburse authorised push payment fraud themselves. A manipulated agent that pays a fake invoice is now the bank’s loss.

Identity is not authority. Knowing which agent acted does not tell you what it was allowed to do.

The proposal in one sentence

Before any agent-initiated payment executes, the bank verifies a passport: three signed claims, from the three parties entitled to make them, checked in a fixed order, with one answer and one reason.

The three claims

Who signs	What they say	What they cannot say
The authority (payments supervisor)	This provider is licensed. This agent passed assurance. Here is the condition a human officer attached. Here is where to check whether this is still true.	Which agent key is in use today. What the customer allows.
The provider (the firm running the agent)	This is the agent, this is its public key, this is its software and configuration.	That it is assured. What the customer allows.
The customer (whose money it is)	These payees, this cap per payment, this cap per month, this expiry.	Anything about assurance or the agent’s key.

Each claim is a signed token. Nobody can alter what another party signed. Remove any one and the bank refuses.

The verify call

The agent signs every payment instruction with its own key and presents its passport. The bank asks nine questions, in order, and stops at the first no:

1. Is the authority's signature genuine?
2. Is the passport still active in the authority's registry?
3. Is the provider's claim genuine and the one the authority assured?
4. Did the agent's own key sign this instruction?
5. Is the customer's mandate present, signed and unexpired?
6. Is this action allowed and this payee on the customer's list?
7. Is the amount within the per-payment cap?
8. Is the running monthly total, kept by the bank, still within the cap?
9. Is the amount below the supervisor's human-confirmation condition?

The answer is **ALLOW**, **ESCALATE** to a named human, or **DENY**, always with the rule that decided it and a receipt signed by the authority. Every decision is recorded in a tamper-evident log and can be replayed later to the same answer.

The lifecycle

- **Issue.** The provider submits evidence. An assistant reads it into facts with page references, maps them to written rules, and tests the passport against adversarial cases. A human officer decides and signs.
- **Act.** The bank verifies each instruction before money moves.
- **Detect.** Every refusal is logged. A repeated refusal of the same kind raises an alert to the supervisor.
- **Revoke.** The supervisor suspends or revokes. The registry flips one row. The agent's next instruction fails everywhere, including on any rail that mirrors the mandate.

What the standard is built from

Nothing invented. JSON Web Tokens with Ed25519 signatures. Scope expressed as an OAuth 2.0 Rich Authorization Request. Key binding by proof of possession. Status by registry lookup. A hash-chained log. Rules shipped as versioned data, not code, so an authority can change policy without changing software.

What it does not do

It does not move money. It does not replace the provider's licence, the customer's contract or the bank's own checks. It does not judge whether an invoice is wise, only whether the agent had authority to pay it. It does not let a machine decide anything consequential: the model reads and drafts, rules decide, humans sign.

Why it is a standard and not a product

Any authority can issue. Any bank can verify with one call. Any rail can settle. Swap the rule pack and the same engine authorises a tax-filing agent instead of a payments agent, which we

have built and deployed. Delegation can only narrow authority, never expand it, and that property holds however many agents sit in the chain.

One line

Firms want to automate payments, banks are liable for what agents authorise, and regulators cannot see any of it. Agent Passport lets an agent prove, before the money moves, exactly what it is allowed to do and who answers for it.